

# Cloud Storage Misconfiguration Exposure response

Cloud · **Critical** severity · SOC IR Playbook

|                   |                                                                                                                           |
|-------------------|---------------------------------------------------------------------------------------------------------------------------|
| Incident type     | Data Exposure - Misconfiguration                                                                                          |
| Severity          | Critical                                                                                                                  |
| Priority          | High                                                                                                                      |
| Detection sources | Cloud Security Posture Management (CSPM), SIEM, Threat Intel, External Notification (e.g., researcher, media), Audit Logs |

## Scenario

Sensitive or confidential data (e.g., logs, databases, personal information) is exposed to the public due to misconfigured permissions on cloud storage services, often discovered via threat intelligence feeds, automated scanners or internal audits.

## MITRE ATT&CK

T1530, T1562.007

## Preparation

Enforce default secure policies Block public access at the organisation level for cloud storage services Implement CSPM tools Continuously monitor for misconfigurations (e.g., Wiz, Prisma Cloud, AWS Config) Enable access logging For cloud storage services (e.g., AWS S3 access logs, Azure diagnostics) Tag and classify sensitive data Use data classification tools to mark high-risk information Perform regular cloud audits Review access settings for storage buckets, blobs and containers

## Detection & Analysis

Receive alert from CSPM or threat intel Example: "Public read access detected on S3 bucket storing backup files" Review object permissions Determine which files are exposed and who can access them (public, anonymous, specific users) Assess data sensitivity Identify types of exposed data (e.g., PII, financial, passwords, API keys) Check access logs Identify if any unauthorised access has occurred (IP addresses, timestamps)

## Containment

Restrict public access immediately Remove 'public-read', 'allUsers' or 'anonymous' permissions from bucket or object Disable sharing links Revoke signed URLs or public object URLs Notify affected teams Alert data owners, compliance and security teams for risk assessment Quarantine compromised credentials If API keys or credentials were exposed, rotate immediately

## Eradication

Review and fix IAM policies Audit and adjust overly permissive roles or storage policies Enable bucket/block-level protection Enforce default encryption, versioning and public access blocking Clean exposed data Remove or archive unnecessary files, scrub exposed content Reconfigure secure sharing mechanisms Use identity-based access controls instead of public sharing links

## Recovery

Validate proper access controls Confirm access is restricted to intended users and services Confirm data integrity Ensure no tampering or unauthorised modifications occurred Resume operations Restore use of cloud storage once properly secured Update inventory Reflect current access control status in asset and data tracking systems

## Lessons Learned & Reporting

Conduct root cause analysis Identify whether exposure was due to human error, policy failure or automation Update CSPM and SIEM detections Tune alerts for permission drift and external access attempts Train developers and DevOps teams Reinforce secure configuration practices in CI/CD pipeline Report if required Notify regulators

or customers if PII or confidential data was exposed Document lessons learned Update cloud governance policies and incident playbooks accordingly

### ***Tools typically involved***

CSPM tools (e.g., Wiz, Prisma Cloud orca, AWS Config, Microsoft Defender for Cloud); SIEM (e.g., Sentinel, Splunk); Cloud audit logs (e.g., AWS CloudTrail, Azure Activity Logs, GCP Admin Activity); IAM systems (e.g., AWS IAM, Azure AD, Google IAM); DLP or classification systems (e.g., Microsoft Purview, Symantec DLP)

### ***Success metrics (SLA targets)***

Detection Time <1 hour from exposure Access Removal Time <30 minutes from alert Public Exposure Duration Ideally <1 hour Impact Assessment Completion Within 24-48 hours Policy Remediation Time Within 72 hours